

Passive Information Gathering (OSINT)

Module 2 — Reconnaissance · Unit 07

The first time we gather information about a target. We start where it matters most:
ethics.

Where we are in the course

- **Module 1:** Foundations, ethics, the lab, networking, Linux, scripting.
- **Module 2 — Reconnaissance** (you are here):
 - **Unit 07 — Passive recon (OSINT)** ← this week
 - Unit 08 — Active recon & scanning
 - Unit 09 — Vuln scanning & enumeration → recon mini-project
- Recon is step one of every real assessment. You can't attack — or defend — what you don't understand.

Learning objectives (1 of 2)

By the end of this unit you can:

- **Place** recon in the attacker lifecycle: recon → scanning → exploitation → post-exploitation → reporting.
- **Distinguish** passive from active information gathering, with an example of each.
- **Name and explain** at least six OSINT sources.
- **Build** a Google "dork" using search operators.

Learning objectives (2 of 2)

- **Look up** WHOIS and DNS records and explain each field.
- **Extract** metadata from a document and explain why it leaks.
- **Evaluate** your own digital footprint and list steps to shrink it.
- **Explain** the legal/ethical limits of OSINT — "it's public" ≠ "anything goes."
- **Produce** a short, professional mini OSINT report.

Vocabulary — the recon process

Term	Meaning
Reconnaissance (recon)	The info-gathering phase — learn about a target before doing anything.
Attacker lifecycle	The ordered phases: recon → scanning → exploitation → post-exploitation → reporting.
Passive info gathering	Collecting info <i>without</i> touching the target's systems.
Active info gathering	Directly probing the target (scanning) — next unit; needs authorization.
OSINT	Open-Source Intelligence — info from publicly available sources.

Vocabulary — sources & infrastructure

Term	Meaning
Footprint	The trail of public info about a person or org online.
WHOIS	Public record of who registered a domain (registrar, dates, contacts).
DNS record	The internet "phonebook" — maps names to addresses/services.
Subdomain	A name under a main domain, e.g. <code>mail.example.com</code> .
Certificate transparency (CT)	Public logs of issued TLS certs; can reveal hostnames.

Vocabulary — techniques & limits

Term	Meaning
Google dorking	Using advanced search operators to find specific public info.
Search operator	A keyword that narrows a search (<code>site:</code> , <code>filetype:</code> , <code>intitle:</code> , <code>inurl:</code> , <code>-</code>).
Metadata	"Data about data" — hidden info in files (author, software, GPS, time).
Breach data	Info exposed in a past breach. Awareness only — we never download/use it.
Attack surface	All the points where a target could be probed or attacked.
Scope	The agreed boundary of what you're allowed to look at.

Day 1

Recon overview, the attacker lifecycle, passive vs active

Warm-up

Imagine you want to learn **everything** about a new school before your first day — *without* setting foot on campus.

How would you do it? Brainstorm on the board:

- Its website, social media, news articles
- Maps, photos, the sports schedule
- People who already go there

That's OSINT. Everything public, nothing touched.

The attacker lifecycle

Real attacks (and real pentests) follow an order:

- 1. Reconnaissance** — gather information ← *we are here*
- 2. Scanning** — probe live systems
- 3. Exploitation** — break in
- 4. Post-exploitation** — what you do once inside
- 5. Reporting** — write it all up

You can't exploit what you haven't found. **Recon comes first.**

Passive vs active — the key split

	Passive (this unit)	Active (next unit)
Touches the target?	No	Yes — sends packets
Sources	Public records, third parties	The target's own systems
Example	Read a job posting	nmap a web server
Authorization	Still bound by law/ethics	Legally required

Passive recon collects information that is **already public**, without ever touching the target.

Passive ≠ "anything goes"

- Passive recon rarely breaks computer-intrusion law *by itself* — you never touch the target.
- **But** pointing recon at a real person/org you have no right to assess can still be:
 - **Stalking / harassment**
 - **Privacy violations**
 - The **planning stage** of a crime

"It's public" is **not** the same as "ethical to use."

Recon is a defender skill too

- Attackers profile *you* — so you should profile yourself first.
- If you know what's exposed, you can **shrink** it.
- The same skills that find a target's weak points let a **blue team** reduce its own footprint.

The one rule — even for "just looking"

Aggregating public facts about a real person is doxing
— harmful and often illegal.

We gather info **only** about the teacher-seeded fictional target or **our own** footprint.
Never a real classmate, teacher, or business.

What is doxing?

- **Doxing** = collecting and combining public facts about a real person to expose, threaten, or harm them.
- Every fact (employer, gym schedule, kid's school) was *individually* public.
- Combined, they create something **new and dangerous**.

Authorization and scope apply even to "just looking." Where is the line between **research** and **surveillance**? Hold that thought.

Guided practice: passive or active?

Classify each. Which need authorization?

Activity	Passive / Active
Read the company's public job postings	Passive
Scan their web server with nmap	Active
Look up their WHOIS record	Passive
Log into their admin panel	Active (and illegal)
Search the company name on Google	Passive

Exit ticket — Day 1

Give **one example of passive recon** and **one example of active recon**, and state **which one requires authorization**.

Day 2

Domain & infrastructure OSINT: WHOIS, DNS, certificate transparency

Warm-up

When a company registers a website, what **public records** does that create?

- Someone had to **register the domain** → WHOIS record
- The domain needs to **resolve to a server** → DNS records
- The site uses **HTTPS** → a public TLS certificate

All three are public. All three leak information.

WHOIS — who registered the domain

A public record created when a domain is registered. It can show:

- **Registrar** (e.g., GoDaddy, Namecheap)
- **Registration date** and **expiry date**
- **Name servers**
- Sometimes the **registrant contact** (often redacted for privacy)

```
whois brightleafcoffee.example
```

WHOIS — even redacted records leak

Many registrants use **privacy redaction**, hiding contacts.

Redaction does **not** mean "nothing learned."

- **Registration dates** hint at how established the org is.
- **Registrar + name servers** reveal who hosts them.
- A domain expiring next month is a different risk than a 10-year-old one.

DNS — the internet's phonebook

DNS maps names to addresses and services. Key record types:

Record	Points to	Reveals
A	An IPv4 address	Where the site lives
MX	Mail servers	Email provider / self-hosted mail
NS	Name servers	Who runs their DNS
TXT	Free text (SPF, etc.)	Email vendors, verification tokens
CNAME	Another name (alias)	Third-party services

Looking up DNS records

```
dig brightleafcoffee.example A
dig brightleafcoffee.example MX
dig brightleafcoffee.example NS
dig brightleafcoffee.example TXT
```

- `dig <domain> <type>` asks DNS for one record type.
- Browser alternative: any online "DNS lookup" tool.

What does MX reveal? Whether they run their own mail or use a provider — and which one.

Subdomains and attack surface

- A **subdomain** is a name under the main domain: `mail.`, `vpn.`, `dev.`
- Each one can be a separate server — a separate **door**.
- More subdomains = a bigger **attack surface**.

An unadvertised `dev.brightleafcoffee.example` is gold: dev systems are often weaker and not meant to be public.

Certificate transparency (CT) logs

- Every TLS (HTTPS) certificate issued is recorded in **public CT logs**.
- Certificates list the hostnames they cover — including subdomains a company never advertised.

```
Search a CT-log tool for: brightleafcoffee.example  
→ returns: www. mail. dev. ...
```

CT logs can surface `dev.`, `staging.`, and `vpn.` hosts the company forgot were exposed.

Lab Part A — domain & infrastructure recon

On the **authorized seeded target** only:

1. **WHOIS** the domain → record registrar, dates, name servers.
2. **DNS**: look up A, MX, NS, TXT → note what MX reveals.
3. **CT / subdomains**: list any subdomains that appear → flag the `dev.` host.

Record which fields are present and what each tells a defender *or* an attacker.

Exit ticket — Day 2

What does an **MX record** tell an attacker or a defender? What does **certificate transparency** leak?

Day 3

Search-engine OSINT (Google dorking), job postings, social media

Warm-up

What is this search doing?

```
site:gov filetype:pdf budget
```

- `site:gov` → only `.gov` sites
- `filetype:pdf` → only PDF files
- `budget` → containing the word "budget"

It finds **already-public** budget PDFs on government sites — faster.

Google dorking — what it is (and isn't)

- **Dorking** = using advanced search operators to find specific public info.
- It surfaces **already-public** pages more efficiently.

Dorking is **not** breaking in. But pointing it at a real org to hunt for exposed secrets is **not authorized work**.

Search operators cheat sheet

Operator	Does	Example
<code>site:</code>	Limit to one site	<code>site:example.com</code>
<code>filetype:</code>	Limit to a file type	<code>filetype:pdf</code>
<code>intitle:</code>	Word in the page title	<code>intitle:"index of"</code>
<code>inurl:</code>	Word in the URL	<code>inurl:admin</code>
<code>-</code>	Exclude a term	<code>-site:example.com</code>
<code>"..."</code>	Exact phrase	<code>"BrightLeaf Coffee"</code>

Building a dork

Find only PDF files on the single site `example.com`:

```
site:example.com filetype:pdf
```

Find open directory listings on a site:

```
site:example.com intitle:"index of"
```

Combine operators to narrow results to exactly what you want.

Job postings leak the tech stack

A real posting might say:

"Must know **Apache 2.4, Windows Server 2016, Cisco ASA, MySQL.**"

- Each named product/version is a clue to the **tech stack**.
- Named **versions** → known-vulnerability leads (foreshadows Unit 09).
- The company told you for free.

Social media leaks people and habits

- **Who** works there (names, roles, org chart)
- **Habits** (when they're online, where they travel)
- **Tech** (a sysadmin posting about a tool they use)

People are often the easiest "system" to enumerate — and the hardest to patch.

Lab Part B — search-engine OSINT & tech-stack inference

On the **seeded dataset/sandbox** (not the live internet against a real org):

```
site:brightleafcoffee.example filetype:pdf  
site:brightleafcoffee.example intitle:"index of"  
"BrightLeaf" filetype:xlsx -site:brightleafcoffee.example
```

- Record each dork, what it was **meant** to find, and what it **returned**.
- Read the seeded **job posting** → list every technology → infer the stack.

Exit ticket — Day 3

Write a **dork that finds only PDF files** on a single given site.

Day 4

Document metadata, breach-data awareness, and your own footprint

Warm-up

True or false: a photo you post can contain the **GPS coordinates** of where it was taken.

True. Phones often embed location in photo metadata.

Why does that matter? A "harmless" selfie can reveal your home, school, or daily route.

Metadata — "data about data"

Hidden info stored inside files:

- **Author / username** who created it
- **Software + version** used to make it
- **Timestamps** (created, modified)
- **GPS coordinates** (in photos)

You see the document. The metadata is the part you *don't* see.

Why metadata is an attacker's gift

A sample PDF's metadata might show `Author = j.okafor`, `Software = LibreOffice 7.2`.

- `j.okafor` is a likely **username format** (`first-initial-last-name`) → useful in later attacks.
- `LibreOffice 7.2` is a **version** → a CVE lead.
- Timestamps and GPS add even more.

```
exiftool sample-brochure.pdf
```


Breach-data awareness (awareness ONLY)

- Old data breaches expose emails and passwords publicly.
- This is **why password reuse is dangerous** — a leak from one site can unlock others.



We do **NOT** download breach dumps or check anyone else's email.
Awareness only.

The takeaway: use **unique passwords** (motivates password managers, Unit 14).

Flip to defense — audit your own footprint

Now the blue-team move: shrink **your** exposure.

- **Search yourself** — what's public?
- **Privacy settings** — make profiles private.
- **Strip metadata** before posting documents/photos.
- **Unique passwords** + a password manager.

Lab Part C — metadata & your own footprint

1. Metadata: extract from the teacher-provided sample doc.

```
exiftool sample-brochure.pdf
```

Record author/username, software + version, timestamps, GPS. Note what each leaks.

2. Your footprint (private): audit **only yourself** with the self-audit checklist. Do **not** search classmates. Keep results private if you wish.

Exit ticket — Day 4

Name **one piece of metadata** that could leak from a document, and **one step** to remove it before sharing.

Day 5

Build the mini OSINT report + ethics wrap-up

Warm-up & ethics re-anchor

Re-read our rule:

Aggregating public facts about a real person is **doxing** — harmful and often illegal, no matter where each fact came from. Authorization and scope still apply, even to "just looking."

What changed in how you think about your **own** footprint this week?

The mini OSINT report — structure

A short, professional report on the **authorized target**:

1. **Target + scope statement** (confirming authorization)
2. **Sources used**
3. **Findings organized by source** (WHOIS/DNS, CT, search/dorking, job posting, metadata)
4. **Defender "so what"** — how to reduce exposure

No real third party may appear in the report.

Findings → defender recommendations

Tie each finding to a fix:

Finding	Defender recommendation
WHOIS exposes registrant	Use domain-privacy redaction
<code>dev.</code> subdomain in CT logs	Take it offline or firewall it
Job posting lists exact versions	Write generic postings
Doc metadata leaks username/GPS	Strip metadata before sharing

Lab — assemble & submit

- Pull together your Parts A–C findings into the **mini OSINT report**.
- Include the **scope statement** at the top.
- Add your **3 concrete steps** to shrink your own footprint.

This report **feeds forward** into the Module 2 recon mini-project in Unit 09.

Recap — what we learned

- Recon is **step one**; passive recon never touches the target.
- **WHOIS / DNS / CT logs** reveal infrastructure and attack surface.
- **Dorking** finds already-public content faster — not hacking.
- **Metadata** leaks usernames, software versions, and GPS.
- **Breach awareness** → use unique passwords.
- "It's public" ≠ "ethical to use." **Scope + authorization always apply.**

Key vocabulary — quick review

Term	Meaning
OSINT	Intelligence from publicly available sources
Passive recon	Gathering info without touching the target
WHOIS / DNS	Registration record / name→address mapping
CT log	Public TLS-cert log (leaks hostnames)
Dorking	Advanced search operators for public info
Metadata	Hidden "data about data" inside files
Doxing	Harmful aggregation of a real person's public facts
Scope	The agreed boundary of what's allowed

Discussion

Every fact in a person's "dossier" — their employer, their gym schedule, their kid's school — was individually public.

Does combining public facts create something **new and harmful**?

Where's the line between **research** and **surveillance/doxing**? Who decides?

Exit ticket — Day 5 + homework

Exit ticket: one sentence on the legal/ethical line of OSINT.

Homework:

- Complete the **digital-footprint self-audit** → write 3 concrete actions.
- ½-page: "Why is 'it's public' not the same as 'ethical to use'?" Use **scope**, **doxing**, **authorization**.

Next up — Unit 08: Active Information Gathering & Scanning (we start sending packets).